Threatlint Setup Quick-Start

Evidence-led, read-only AppSec agents: Workbench app, CLI, Claude Code, Codex, and GitHub Copilot

threatlint 1.0.0

Prerequisites: **Python** 3.9+ (+ `python-docx` for Word) **Node.js** 22+ & npm (Workbench) **git** **Model:** LM Studio (local), Anthropic, OpenAI, Copilot

1 Electron desktop app (Workbench UI)

Install and launch (from the repo root)

```
git clone <threatlint-repo-url>
cd threatlint
npm --prefix web ci
npm --prefix web run desktop  # Electron
npm --prefix web start  # or browser :3000
```

Both run the same code. Packaged build: `npm --prefix web run desktop:dist`.

First-run settings (sidebar → Settings)

- **Model:** LM Studio `http://localhost:1234/v1` → **Load models**; or Anthropic, OpenAI (API key env vars), Copilot (`gh auth login`). Cloud needs consent.
- **Sources:** a GitHub App (Settings → GitHub, 6) or fine-grained PAT, or an Azure DevOps PAT + organization (Code: Read).
- **If used:** ServiceNow (instance URL + OAuth client), Semgrep API token, Azure DevOps PAT: FP review needs all three.

First scan

1. Open a repository from the top bar, or **Sources** → search → branch → **Check out & open workspace**.
2. Choose a playbook: **Pull request review** or **Security baseline**. Add an optional scope.
3. **Run**, follow live activity, then open **Reports** and download Markdown or Word.

No model yet? Use **View sample report**.

2 CLI

```
pip install threatlint   # or: pip install -e .
threatlint setup --check  # what is missing
threatlint setup          # one-time prompts
```

`setup` configures AWS SSO, ServiceNow, an Azure DevOps PAT, and a Semgrep token; it is only needed for ServiceNow/AVIT workflows. Individually: `threatlint ado login --organization <org>`, `threatlint semgrep login`, `threatlint github login` (6).

First commands

```
threatlint list            # bundled agents
threatlint guard --staged  # offline check
threatlint run threat-model  # LM Studio
# OpenAI instead (reads OPENAI_API_KEY):
threatlint run security-review --provider openai \
  --base <sha> --head <sha>
```

3 Claude Code

```
threatlint install -y          # ~/.claude/
threatlint install --local -y  # ./.claude/
# CLAUDE.md rules + PostToolUse guard hook:
threatlint ide install --editors claude
```

Installs the agents, slash commands, and complete skills. Commit `.claude/` to share with a team. Check: type `@` to see the agents and `/` to see the commands.

Example slash commands

```
/threat-model          # auto-discover
/security-review main..feature
/security-review 42    # PR number
/secrets-scan
```

Output: `<repo>-<branch>-threat-model-YYYY-MM-DD.docx`

4 OpenAI Codex (AGENTS.md)

Global (every repository)

```
mkdir -p ~/.codex
cp /path/to/threatlint/AGENTS.md ~/.codex/AGENTS.md
```

Per repository (team use, commit it)

```
cd /path/to/your-repo
cp /path/to/threatlint/AGENTS.md AGENTS.md  # or >> append
```

Word output: copy `.claude/scripts/md_to_docx.py` to `~/.claude/scripts/`.

Invoke with plain language

```
threat model this repository
security review the current diff
review PR #42 for security regressions
```

5 GitHub Copilot

```
threatlint install --copilot --local -y  # ./.github/
threatlint install --copilot -y   # or ~/.copilot/
threatlint ide install --editors copilot # rules
```

Commit `.github/`, open the repo as a **trusted** VS Code workspace with Copilot Chat enabled, and reload the window once.

Invoke in Copilot Chat

```
@AppSec Threat Modeler threat model src/auth
@AppSec Code Reviewer review this PR for auth bypasses
/Discover Application Threat Model
```

Pick agents from the agent picker (`@`); `/` lists the prompts. Reports stay in chat; Copilot Chat does not write Word files.

6 GitHub App (optional: GitHub clones, Sources, PR comments, issues)

1. GitHub → Developer settings → **New GitHub App** (webhook off). Permissions: **Metadata** + **Contents: read**; **Pull requests** / **Issues: read & write** only for PR comments / issues.
2. **Generate a private key** (.pem, `chmod 600`), **Install** on your org, note the App ID and installation ID.

```
threatlint github login --app-id <id> --installation-id <id> \
  --private-key-file <path/to.pem>   # then: threatlint github status
```

Workbench: Settings → GitHub → **Use GitHub App**. Config stays in `~/.threatlint/github-app.json` (0600, key path only), never committed. Credential order: App → `GH_TOKEN` → `gh`. Guide: `docs/github-app.md`.

All Threatlint agents are analysis-only: they read source and never modify the workspace. Treat reports as sensitive. Details: `README.md`, `docs/workbench.md`, `docs/ide.md`.